

Unsupervised Detection of Attack Surface Drift

CS 4412 Project Proposal

Alec Sundby
Department of Computer Science
Kennesaw State University
Marietta, USA
asundby@student.kennesaw.edu

This proposal outlines our project to apply unsupervised data mining to the field of Attack Surface Management (ASM). We are using the LANL Cyber Security dataset to find patterns of software drift and Shadow IT that standard security tools often miss. We are going to use PCA for dimensionality reduction, DBSCAN for clustering, and Isolation Forests to find statistical outliers in network telemetry. These three tactics work together as a pipeline. PCA acts as the first layer to compress the high-dimensional logs, which makes it feasible for DBSCAN to identify behavioral clusters. The Isolation Forest then processes the data to rank anomalies. This combined approach will allow us to identify outliers more accurately compared to using a single algorithm on the raw, high-dimensional data.

I. INTRODUCTION

It is a known fact that enterprise networks are constantly changing. Therefore, software configurations drift away from secure baselines because of system updates, user behavior, and unauthorized changes known as Shadow IT. Most security tools look for signatures of known attacks, which means that they miss new or unknown configuration states.

We want to look at unlabeled data to see if natural formations of groups can be dictated based on their behavior. If a device or user drifts away from these groups, it could be noted as a security risk. Our analysis focuses on enterprise-scale telemetry to try and determine the difference between normal administrative work and anomalies that need to be investigated.

II. DATASET DESCRIPTION

A. Name and Source

The dataset for this project is the LANL Cyber Security Dataset from Los Alamos National Laboratory. It contains real authentication and network activity from the Los Alamos National Laboratory enterprise network.

B. Size and Scope

The dataset has millions of log entries, which is too large for our hardware. Therefore, we will use a sampled subset of 50,000 to 100,000 records to keep it feasible while still having enough data to see patterns.

- Target Size: Approximately 50,000 to 100,000 records.
- Content: Authentication events and network connection logs.

C. Key Attributes

We will extract the following features for our discovery process:

- Timestamps: To find time-series patterns in system usage.
- Host Relationships: To map which machines talk to each other.
- Authentication Outcomes: To find success and failure patterns.
- User IDs: To track behavior across different devices.

III. DISCOVERY QUESTIONS

This project focuses on discovery questions to reveal the structure of the data rather than predicting specific labels.

A. DQ1: Behavioral Clustering

Are there natural clusters of system behavior that separate normal operations from weird usage patterns? If we can find these clusters, we can identify drift without needing a dataset that is already labeled with attacks.

B. DQ2: Concept Drift

Which entities show significant changes in their behavior over time? This helps us find systems or users that might be using unauthorized software or have compromised credentials.

IV. PLANNED TECHNIQUES

Our analysis follows a three-stage pipeline for unsupervised learning.

A. Dimensionality Reduction (PCA)

PCA will be used to compress high-dimensional data into a smaller space. This helps us visualize behavior and see if drift shows up as movement away from the dense regions where normal activity occurs.

B. Clustering (DBSCAN)

We will use DBSCAN to find regions of normal behavior. We chose this because we do not need to tell it how many clusters to find. Points that do not relate to these regions are likely to represent drifting behavior.

C. Anomaly Detection (Isolation Forest)

Isolation Forests will be used to give anomaly scores to different events. If an event is easy to isolate with few splits, it gets a higher score. This gives us a way to rank potential drift cases for further investigation.

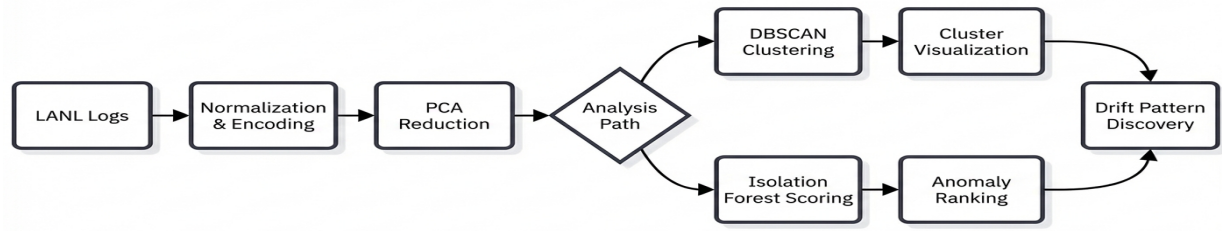


Fig. 1. Data Mining Pipeline for Pattern Discovery.

V. EVALUATION AND VALIDATION

Evaluating unsupervised models is challenging due to the lack of direction/definition of an unwarranted connection. We will use the following metrics to validate our discoveries:

A. Internal Evaluation

We will utilize the Silhouette Coefficient and Davies-Bouldin Index to assess the cluster's quality, which we will then relate to the variables that we plan to extract from the datasets. A high Silhouette score will indicate the behavioral clusters as being well-defined and distinct, which suggests that the baseline is normal. Additionally, we will look for a low Davies-Bouldin Index because that will indicate a favorable ratio of within-cluster scatter to between-cluster separation. These metrics will be applied throughout our tuning phase as we utilize DBSCAN's epsilon and min_samples parameters to establish a baseline understanding of the network activity. The purpose of using both metrics is to objectively determine the most applicable configuration that will return the most distinct behavioral groups before we delve into the anomaly detection itself. The Silhouette score is how we can understand the baseline behaviors, while the Davies-Bouldin score will allow us to visualize the distance/distinction of data clusters and Shadow IT points.

B. Anomaly Verification

The anomalies that are identified by the Isolation Forest will be utilized for a qualitative observation. We will take these suspected anomalies and cross-reference high scoring outliers with the original LANL event logs. From this point we will be able to see if they correspond to known administrative patterns or harmless irregularities.

C. Conclusion

The aim of this project is to ultimately create and demonstrate the ability to delimit behavioral analysis when regarding Attack Surface Drift. This will be identified through statistical deviations in the network telemetry by implementing a pipeline of PCA, DBSCAN, and Isolation Forests.

VI. PRELIMINARY TIMELINE

- Milestone 2: Download the data, sample it, and handle the feature encoding and normalization.
- Milestone 3: Apply PCA and DBSCAN, tune the parameters, and generate the anomaly scores.
- Milestone 4: Look at the high-scoring anomalies and see if the patterns actually represent meaningful drift.

VII. GITHUB REPOSITORY

Repository Name: `cs4412-asm-mining` <https://github.com/asundby6/cs4412-asm-mining>

REFERENCES

- [1] M. Turcotte, A. Kent, and C. Hash, "Unified Host and Network Data Set," in *Data Science for Cyber-Security*, World Scientific, Nov. 2018, pp. 1–22. [Online]. Available: <https://csr.lanl.gov/data/2017/>